Vulnerability Assessment Report

AuSecurity Vulnerability Assessment Report

AuSecurity (Ausecurity)
63 Paddington St
Paddington NSW 2021, Australia

Flinders University
Sturt Road, Bedford Park SA 5042

October 5, 2026

Report Version: 1.0

CONFIDENTIAL

Table of Contents

List of Figures 3

1 Document Control 4

1.1 Team 4

1.2 List of Changes 4

2 Executive Summary 5

2.1 Overview 5

2.2 Identified Vulnerabilities 5

3 Methodology 7

3.1 Objective 7

3.2 Scope 7

3.3 User Accounts and Permissions 8

4 Findings 9

H1: Unauthenticated admin dashboard exposes client and business data 9

M1: Self-signed TLS certificate 10

M2: DOM-based cross-site scripting on the consultation success page 11

M3: Missing HTTP security headers 12

M4: Missing SPF and DMARC records 13

M5: HTTPS /api path redirects to HTTP 14

M6: Open redirect after login via the redirect parameter 15

I1: Web server version disclosed 16

5 Disclaimer 17

A Appendix 18

A.1 Static Appendix Section 18

A.2 Methodology 18

A.3 Limitations 18

A.4 Coverage 18

List of Figures

Figure 1 - Distribution of identified vulnerabilities 6

1 Document Control

1.1 Team

Contact	Details	Role
ClawSec	Autonomous agent	Pentester

1.2 List of Changes

Version	Description	Date
1.0	Final report	Oct 5, 2026

2 Executive Summary

2.1 Overview

Executive Summary

Ausecurity delivers expert GRC consulting and penetration testing services to businesses across Australia. This report covers an authorized security assessment of the public website. Testing was performed on 5 October 2026 with the owner's permission and was limited to **ausecurity.best**.

Overall result

The assessment confirmed **8 findings**: **1 high**, **4 medium**, **2 low**, and **1 informational**.

This report keeps the CVSS vectors from the verified findings file. Two items labelled low in that file (the HTTPS-to-HTTP redirect on `/api`, and missing SPF/DMARC) score as medium under CVSS 3.1. The chart therefore shows 1 high, 6 medium, and 1 informational.

The most serious issue is that the admin dashboard is reachable without logging in. It includes client-looking contact details and internal business figures. The site only tries to hide this with JavaScript after the page is already sent.

A "thank you" page can run script from the address bar (cross-site scripting). The login page can send users to an attacker site after sign-in. HTTPS uses a self-signed certificate, and standard browser-protection headers are missing.

Lower-priority issues are an HTTPS-to-HTTP redirect on `/api`, no SPF or DMARC email-authentication records, and nginx version disclosure.

Highest-priority actions

1. Take the dashboard off the public internet until server-side login is required.
2. Fix the thank-you page to use text, not HTML.
3. Install a trusted certificate.
4. Add security headers.

2.2 Identified Vulnerabilities

#	CVSS	Description	Page
H1	7.5	Unauthenticated admin dashboard exposes client and business data	9
M1	6.8	Self-signed TLS certificate	10
M2	6.1	DOM-based cross-site scripting on the consultation success page	11
M3	5.4	Missing HTTP security headers	12

#	CVSS	Description	Page
M4	5.3	Missing SPF and DMARC records	13
M5	4.8	HTTPS /api path redirects to HTTP	14
M6	4.3	Open redirect after login via the redirect parameter	15
I1	0.0	Web server version disclosed	16

Vulnerability Overview

In the course of this penetration test **1 High**, **6 Medium** and **1 Info** vulnerabilities were identified:

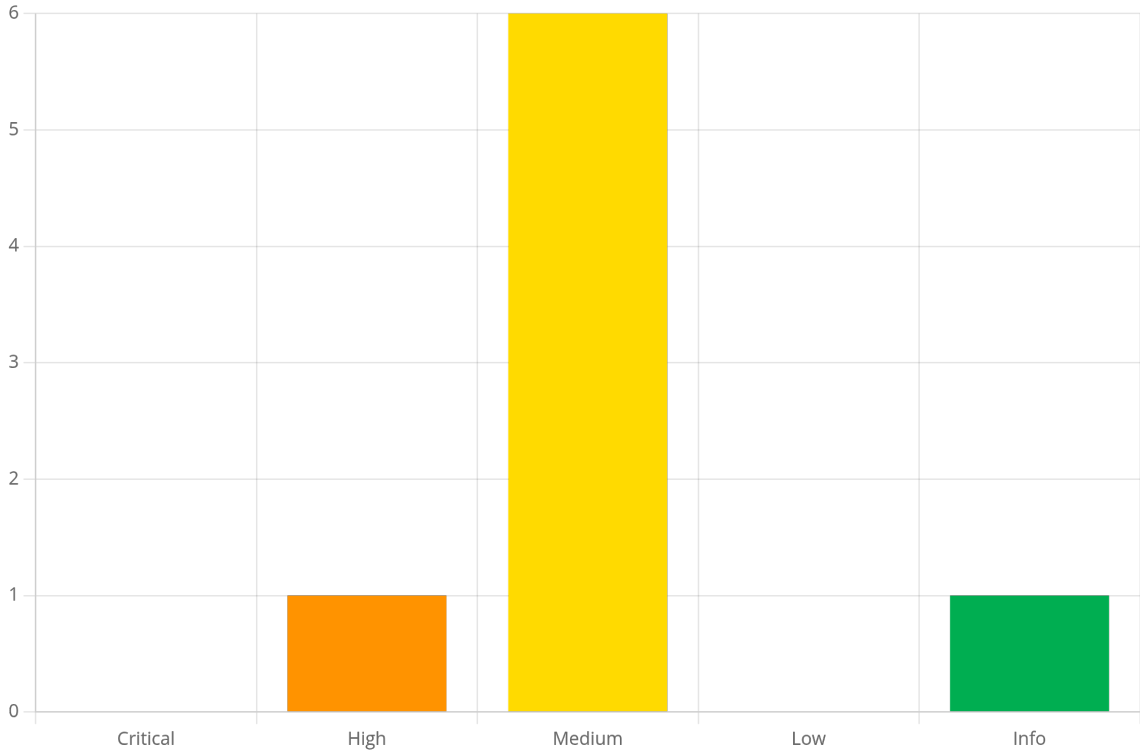


Figure 1 - Distribution of identified vulnerabilities

3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasiable, seamless and cost-affective such approach is.

3.2 Scope

This assessment covered only the owner-approved public website. Testing was performed on 5 October 2026 after authorization was confirmed via a required response header on the main public-facing website. The header value is not recorded in this report.

In-scope (owner approved)

System	Description
https://ausecurity.best/	Official public website and same-origin paths on ausecurity.best

Enumerated hosts (inventory only — not tested)

The owner explicitly did not approve the following for testing:

- www.ausecurity.best (51.79.166.148)
- contact.ausecurity.best (51.79.166.148)
- blog.ausecurity.best (51.79.167.208) — WordPress observed during enumeration only
- ticket.ausecurity.best (51.79.166.209) — osTicket installer observed during enumeration only
- 51.79.166.148 as a general host (unrelated services)

The official website resolves to 51.79.166.148. That address was used only for connectivity to the approved website.

Rejected lookalikes (out of scope)

- ausecurity.com.au
- ausecurity.com
- ausecurity.net

Third-party exclusions (not tested)

OVH AS16276, Spaceship DNS, Google Fonts, Google Maps, and Flinders email infrastructure.

Allowed methods

Authorization check, passive and active enumeration, TLS review, HTTP header review, path discovery, JavaScript and HTML review, unauthenticated access-control checks, a single invalid-login response-shape test, contact-form input tests, and a DNS mail-record check.

Forbidden methods

Brute force, password spraying, denial of service, social engineering, malware, and destructive tests. No exploitation beyond minimum proof.

3.3 User Accounts and Permissions

No user accounts were provided. Testing was unauthenticated only. Cookie security flags were not observed because no authenticated session was obtained.

4 Findings

H1: Unauthenticated admin dashboard exposes client and business data	
Score	7.5 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Target	• https://ausecurity.best/dashboard • https://ausecurity.best/dashboard.html
References	• CWE-285 • CWE-200 • OWASP A01:2021 Broken Access Control

Overview

Anyone can open the admin dashboard in a browser or with a simple request and see internal enquiry and client details. The site tries to send visitors to the login page using JavaScript, but the confidential page content is already sent first.

Details

Unauthenticated GET requests to `/dashboard` and `/dashboard.html` return HTTP 200 with the full "Admin Dashboard — Ausecurity" page (about 16 KB of HTML). The page includes an apparent signed-in admin view, enquiry lists, activity, and business figures such as revenue. Multiple client email addresses were present in the HTML. Those addresses are not repeated here.

The login API correctly rejects anonymous users (`GET /api/auth/me` returns 401 `Not authenticated`). Access control for the dashboard is only in client-side JavaScript in `/assets/js/main.js`, which redirects after the confidential HTML has already been delivered. Search engines, command-line tools, and anyone who disables JavaScript still receive the data.

Business impact: client contacts and internal pipeline information can be read by the public. This can enable phishing, competitor intelligence, and loss of client trust.

Recommendation

Require a valid server-side session before returning any dashboard HTML or data. Return 401/302 from nginx or the application for `/dashboard` without a session cookie. Move dashboard data to authenticated APIs. Treat any data already exposed as potentially compromised and notify affected clients if the records are real.

M1: Self-signed TLS certificate	
Score	6.8 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N
Target	https://ausecurity.best/
References	CWE-295

Overview

The website's HTTPS certificate is self-signed, so browsers will warn visitors and attackers on the network can more easily impersonate the site.

Details

The certificate subject and issuer are both `CN=ausecurity.best`. SAN lists only `ausecurity.best`. Validity is 2026-09-14 to 2027-09-14. SHA-256 fingerprint `B5:30:10:E0:32:E7:42:10:E4:B1:F0:68:A0:C5:B2:A2:0B:F6:44:C1:F3:32:92:87:4D:1C:64:07:14:8D:14:E2`. There is no public CA chain (for example Let's Encrypt).

Business impact: clients may abandon the site, ignore future certificate warnings, or have their traffic intercepted.

Recommendation

Issue a certificate from a public CA covering `ausecurity.best` (and www if used). Enable automatic renewal. Turn on HSTS after the trusted certificate is in place.

M2: DOM-based cross-site scripting on the consultation success page	
Score	6.1 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Target	• https://ausecurity.best/consultation-success.html • https://ausecurity.best/api/contact
References	• CWE-79 • OWASP A03:2021 Injection

Overview

A crafted link can run an attacker's script in a visitor's browser on the "thank you" page. The contact form also puts the visitor's name into that same page address.

Details

`consultation-success.html` reads the `name` query parameter and assigns it to `innerHTML` with no encoding:

```
document.getElementById('user-name').innerHTML = userName;
```

The company name uses the safer `textContent`. `POST /api/contact` returns `redirect_url` including the attacker-controlled name (URL-encoded) and the front end navigates there. A direct visit such as `/consultation-success.html?name=<img src=x onerror=alert(1)>` is enough; login is not required. The site has no Content-Security-Policy to limit script execution.

Business impact: a client or staff member who opens a malicious link can have the page altered, be shown a fake message, or have their session used in the browser.

Recommendation

Use `textContent` for the name, never `innerHTML`. Encode output. Add a strict Content-Security-Policy without `unsafe-inline`. Validate and length-limit contact fields on the server.

M3: Missing HTTP security headers	
Score	5.4 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N
Target	https://ausecurity.best/
References	• CWE-693 • CWE-1021 • OWASP Secure Headers

Overview

The website does not send standard browser-protection headers. That makes clickjacking, protocol downgrade, and script injection easier.

Details

A GET to `/` returned `Server: nginx/1.22.1` and no `Strict-Transport-Security`, `Content-Security-Policy`, `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy`, or `Permissions-Policy`. HTTP `/` does redirect to HTTPS, but without HSTS a later visit can still be forced to HTTP. The unauthenticated admin dashboard can be placed in a third-party iframe.

Business impact: attackers can overlay or frame the admin view, weaken HTTPS, and have a wider window for the XSS issue above.

Recommendation

Send HSTS (`max-age` at least 15552000, includeSubDomains) after a valid public certificate is installed. Add `Content-Security-Policy`, `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`, `X-Content-Type-Options: nosniff`, and a strict Referrer-Policy.

M4: Missing SPF and DMARC records	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Target	ausecurity.best
References	CWE-284

Overview

The domain publishes a contact address but has no mail authentication records, so others can more easily send email that looks like it came from Ausecurity.

Details

`dig` showed no MX, TXT, SPF, DMARC, or CAA records. The public site advertises `info@ausecurity.best`. With no SPF or DMARC, mailbox providers have little instruction to reject spoofed mail.

Business impact: clients may receive fake invoices, fake pentest reports, or credential-harvesting messages using the company name.

Recommendation

If the mailbox is unused, do not advertise it. Publish `v=spf1 -all` and a DMARC policy (`p=reject` once monitoring is done). If mail will be used, add MX and a correct SPF include for the provider.

M5: HTTPS /api path redirects to HTTP	
Score	4.8 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
Target	https://ausecurity.best/api
References	CWE-319

Overview

Asking for the API folder over HTTPS sends the browser to an HTTP (unencrypted) address.

Details

`GET https://ausecurity.best/api` returns `301` with `Location: http://ausecurity.best/api/`. The site root correctly redirects HTTP to HTTPS, but this API slash-redirect drops TLS.

Business impact: a network attacker can intercept or change that follow-up request.

Recommendation

Redirect to https://ausecurity.best/api/ and keep HTTPS. Prefer an nginx redirect that preserves the HTTPS scheme, the host, and the request URI. Disable HTTP except for the HTTPS redirect.

M6: Open redirect after login via the redirect parameter	
Score	4.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N
Target	• https://ausecurity.best/login • https://ausecurity.best/login.html • https://ausecurity.best/assets/js/main.js
References	CWE-601

Overview

After sign-in, the site sends the user to whatever address is in the `redirect` query parameter. A phishing page can be made to look like it started on Ausecurity's login.

Details

`/assets/js/main.js` contains a comment "Safety check: only allow same-origin redirects" but then does `window.location.href = params.get('redirect')` with no allowlist, no leading-slash check, and no origin check. The same assignment runs if the user is already authenticated and visits `/login?redirect=...`. External URLs such as `https://evil.example/` are therefore accepted.

Business impact: attackers can use the real login page as a stepping stone to a lookalike site and harvest credentials or deliver malware.

Recommendation

Allow only relative paths that start with a single `/` and do not start with `//`. Reject `http:`, `https:`, `javascript:`, and backslash variants. Perform the check in code, not only in a comment.

I1: Web server version disclosed	
Score	0.0 (Info)
Vector string	N/A
Target	https://ausecurity.best/
References	CWE-200

Overview

Responses include the exact nginx version, which helps attackers choose known bugs.

Details

The `Server` header is `nginx/1.22.1` on HTML and JSON responses.

Recommendation

Set `server_tokens off;` in nginx and hide version details in error pages.

5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerabilty assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

A Appendix

A.1 Static Appendix Section

A.2 Methodology

The assessment followed a phased, non-destructive methodology:

1. Authorization check on the main public-facing website before any testing.
2. Passive and active enumeration of company-related assets.
3. Owner confirmation that only https://ausecurity.best/ and same-origin paths were in scope.
4. TLS review of the approved host.
5. HTTP security-header review.
6. Path discovery on the approved host (common wordlist).
7. JavaScript and HTML review of public pages.
8. Unauthenticated access-control checks on the dashboard and related endpoints.
9. A single invalid-login response-shape test.
10. Contact-form input tests.
11. DNS mail-record check for ausecurity.best.

No brute force, password spraying, denial of service, social engineering, malware, or destructive tests were used. Testing stopped at minimum proof.

A.3 Limitations

The following limitations apply to this assessment:

- Other enumerated hosts (www, contact, blog, ticket, and the related IP addresses as general hosts) were not tested because the owner selected only the main website.
- No authenticated session was obtained, so cookie flags were not observed.
- Dashboard client records were not independently verified as production versus demo data. They were still served without authentication.
- Possible unsafe handling of contact field `h` (HTTP 500 when pointing at localhost) was not confirmed as server-side request forgery and is not reported as a finding.
- Testing was performed from a single vantage point on a single day (5 October 2026).
- Third-party infrastructure (OVH AS16276, Spaceship DNS, Google Fonts, Google Maps, Flinders email) was excluded.

A.4 Coverage

Approved host coverage on ausecurity.best:

- Public website over HTTPS, including same-origin paths
- TLS certificate review
- HTTP security headers
- Unauthenticated dashboard access (`/dashboard`, `/dashboard.html`)
- Login page and client-side redirect handling

- Consultation success page and contact form (`/api/contact`)
- `/api` slash-redirect behaviour
- DNS records relevant to email authentication (SPF, DMARC, MX, TXT, CAA)
- Server header disclosure

Enumerated but not tested: www.ausecurity.best, contact.ausecurity.best, blog.ausecurity.best, ticket.ausecurity.best, and IP addresses as general hosts.